CONFIDENTIAL / AUDIT DELIVERABLE

Vulnerability Assessment Report

Live Web Application Configuration & Exposure Audit (Read-Only Scope)

TARGET APPLICATION
Altoro Mutual (testfire.net)

TARGET IP ADDRESS
65.61.137.117

ASSESSMENT SCOPE
Passive Read-Only Analysis

CONDUCTED BY
Harsha H (Cybersecurity Intern)

1. Executive Summary

In October 2026, a passive, non-intrusive cybersecurity assessment was conducted against the public infrastructure of **Altoro Mutual**. The primary objective was to review the organization's public security posture, verify server configurations, identify missing security safeguards, and provide business-friendly remediation guidance.

The assessment identified **10 distinct findings**. Notably, the web portal operates over unencrypted HTTP without automatic HTTPS redirection, and lacks standard HTTP browser defenses (Content-Security-Policy, HSTS, X-Frame-Options).

10	2	4	4
TOTAL FINDINGS	HIGH RISK	MEDIUM RISK	LOW RISK

2. Scope & Ethical Standard

This audit adhered strictly to passive, read-only principles:

Permitted & Executed Activities	Explicitly Prohibited Activities
• Public page inspections & status codes • Response header & cookie security auditing	• No login brute-forcing or credential stuffing • No exploitation of suspected flaws

- Non-intrusive TCP connect port scan
- Configuration & tech stack disclosure analysis

- No Denial-of-Service (DoS) or volume spikes
- No unauthorized database access or alteration

3. Vulnerability Findings Matrix

ID	Vulnerability Title	Severity	Category	Remediation Priority
SEC-01	Cleartext HTTP Transmission (No HTTPS Redirect)	HIGH	Transport Security	Immediate (48 hrs)
SEC-02	Missing Content-Security-Policy (CSP)	HIGH	Client Protection	High Priority
SEC-03	Missing HTTP Strict-Transport-Security (HSTS)	MEDIUM	Transport Security	Next Sprint
SEC-04	Missing X-Frame-Options (Clickjacking)	MEDIUM	UI Redressing	Next Sprint
SEC-05	Insecure Session Cookie Flags (Secure, SameSite)	MEDIUM	Session Management	Next Sprint
SEC-06	Exposed Legacy Mail Ports (25, 110, 143)	MEDIUM	Network Perimeter	Next Sprint
SEC-07	Server Software Disclosure (Apache-Coyote/1.1)	LOW	Information Leaks	Routine Maintenance
SEC-08	Missing X-Content-Type-Options	LOW	MIME Protection	Routine Maintenance
SEC-09	Missing Referrer-Policy	LOW	Data Privacy	Routine Maintenance
SEC-10	Missing Permissions-Policy	LOW	Feature Control	Routine Maintenance

4. Detailed Findings & Recommendations

SEC-01: Cleartext HTTP Transmission (Missing HTTPS Redirection)

HIGH SEVERITY (CVSS 7.5)

WHAT IS THE ISSUE?

The web portal accepts and serves connections over unencrypted HTTP (Port 80) without automatically redirecting visitors to HTTPS.

BUSINESS IMPACT

Financial transactions, login credentials, and session tokens sent by users on public networks (coffee shops, hotels) can be passively intercepted by eavesdroppers, directly violating PCI-DSS compliance.

TECHNICAL EVIDENCE

```
HTTP/1.1 200 OK Host: testfire.net Port: 80 (Cleartext HTTP - No 301/302 Redirect to HTTPS)
```

Remediation: Configure the web server or load balancer to issue a permanent `301 Redirect` for all HTTP requests to their HTTPS equivalent, and deploy an active SSL/TLS certificate.

SEC-02: Missing Content-Security-Policy (CSP) Header

HIGH SEVERITY (CVSS 6.5)

WHAT IS THE ISSUE?

The application does not declare an approved whitelist of trusted script, frame, and media sources.

BUSINESS IMPACT

If an attacker identifies any input injection weakness, the absence of CSP allows arbitrary malicious JavaScript to execute in customer browsers, enabling session hijacking and keystroke logging.

TECHNICAL EVIDENCE

```
Content-Security-Policy header: [NOT CONFIGURED]
```

Remediation: Deploy a Content-Security-Policy header restricting executable scripts to self and approved CDNs: `Content-Security-Policy: default-src 'self'; script-src 'self'; frame-ancestors 'none';`

SEC-03: Missing HTTP Strict Transport Security (HSTS)

MEDIUM SEVERITY (CVSS 5.3)

WHAT IS THE ISSUE?

The web server does not signal browsers to strictly communicate over HTTPS in all future sessions.

BUSINESS IMPACT

Enables Man-in-the-Middle (MitM) SSL-stripping attacks where a victim's connection is surreptitiously downgraded to cleartext HTTP.

TECHNICAL EVIDENCE

```
Strict-Transport-Security header: [NOT CONFIGURED]
```

Remediation: Add the HSTS header: `Strict-Transport-Security: max-age=31536000; includeSubDomains; preload`

SEC-04: Missing X-Frame-Options Header (Clickjacking Risk)

MEDIUM SEVERITY (CVSS 4.3)

WHAT IS THE ISSUE?

Third-party websites are permitted to embed the application within hidden HTML iframes.

BUSINESS IMPACT

Malicious sites can overlay invisible banking action buttons underneath innocent links, tricking users into clicking unauthorized transactions (Clickjacking).

TECHNICAL EVIDENCE

```
X-Frame-Options header: [NOT CONFIGURED]
```

Remediation: Enforce framing restrictions by sending `X-Frame-Options: DENY`.

SEC-05: Insecure Session Cookie Flags (`Secure` & `SameSite` Missing)

MEDIUM SEVERITY (CVSS 5.3)

WHAT IS THE ISSUE?

The primary session cookie (`JSESSIONID`) lacks the `Secure` and `SameSite` protection flags.

BUSINESS IMPACT

Without `Secure`, cookies can leak over unencrypted channels; without `SameSite`, users are vulnerable to Cross-Site Request Forgery (CSRF).

TECHNICAL EVIDENCE

```
Set-Cookie: JSESSIONID=B508E660BE3860065B61B34724ADEDDE; Path=/; HttpOnly
```

Remediation: Configure session management to issue cookies with: `Set-Cookie: JSESSIONID=...; Path=/; Secure; HttpOnly; SameSite=Lax`

SEC-06: Unnecessary Exposure of Legacy Mail Ports (25, 110, 143)

MEDIUM SEVERITY (CVSS 5.0)

WHAT IS THE ISSUE?

The host server exposes unencrypted mail service ports directly to the public Internet.

BUSINESS IMPACT

Broadens the perimeter attack surface, exposing mail daemons to spam relaying and remote exploitation.

TECHNICAL EVIDENCE

```
Port 25/TCP (SMTP) : OPEN Port 110/TCP (POP3) : OPEN Port 143/TCP (IMAP) : OPEN
```

Remediation: Enforce strict firewall rules restricting access to mail ports to authorized internal VPN IPs only.

SEC-07: Server Software Information Disclosure

LOW SEVERITY (CVSS 3.3)

WHAT IS THE ISSUE?

The server broadcasts its internal web server engine identity in response headers.

BUSINESS IMPACT

Helps attackers map server architecture and query vulnerability databases for known CVEs.

TECHNICAL EVIDENCE

```
Server: Apache-Coyote/1.1
```

> **Remediation:** Mask or disable the `Server` header token in Tomcat / Reverse Proxy settings.

5. Remediation Roadmap

```
Phase 1: Immediate Action (Within 48 Hours) • Implement mandatory HTTP → HTTPS 301 Redirection (SEC-01) • Block public access to mail ports 25, 110, 143 via firewall (SEC-06) Phase 2: Short-Term Hardening (1 to 2 Weeks) • Deploy HSTS and X-Frame-Options headers (SEC-03, SEC-04) • Attach 'Secure' and 'SameSite=Lax' to session cookies (SEC-05) Phase 3: Long-Term Posture (Within 1 Month) • Implement strict Content-Security-Policy (SEC-02) • Suppress server banners and apply missing defense headers (SEC-07 - SEC-10)
```